

Indice

Obiettivo report Pag. 1

Infrastruttura Realizzata pag. 2

Configurazione dell'Ambiente di Virtualizzazione pag. 3

Configurazione delle Macchine Virtuali

Configurazione di Rete

Configurazione Active Directory pag. 3

Installazione del Domain Controller

Utenti di Dominio Creati

Aggiunta del Client al Dominio

Verifica dell'Infrastruttura AD

Aggiunta Ubuntu Server e Installazione SIEM pag. 4

Aggiunta di Ubuntu Server e Join al Dominio

Installazione di Splunk Enterprise 10.2.1

Installazione dello Splunk Universal Forwarder

Configurazione del Log Forwarding

Verifica dei Servizi e Connettività

Simulazione dell'Attacco pag. 5

Scenario: Insider Threat + Brute Force Esterno

Fase 1 — Insider Threat

Fase 2 — Attacco Esterno con Hydra

Analisi dei Log su Splunk pag. 6–7

Rilevamento Event ID 4625 — Tentativi Falliti

Rilevamento Event ID 4624 — Accesso Riuscito da IP Anomalo

Conclusioni pag. 8

PROGETTO FINALE

CYBER SECURITY & ETHICAL HACKING
LAB DI SICUREZZA CON ACTIVE DIRECTORY E SIEM

Obiettivo Lab

Il report documenta la realizzazione di un ambiente virtualizzato che simuli una rete aziendale reale, composta da un Domain Controller Windows Server 2022, un client windows 10 pro unito al dominio e un sistema **SIEM** (Security Information and Event Management) basato su splunk Enterprise. L'ambiente permette di monitorare gli eventi di sicurezza generati dall'infrastruttura Active Directory e di simulare scenari di attacco rilevabili dal **SIEM**.

Infrastruttura realizzata

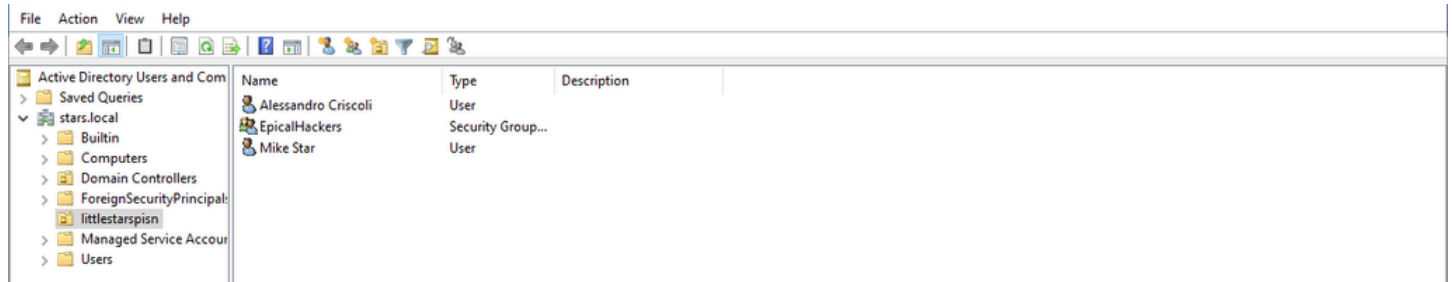
MACCHINA	SISTEMA OPERATIVO	INDIRIZZO IP
DC-Lab (mikeserver)	Windows server 2022	192.168.1.29
Client-Lab	Windows 10 pro	192.168.1.99
SIEM (mslsxr)	Ubuntu server	192.168.1.50

Le macchine virtuali sono state create con Virtual Box e configurate con scheda di rete in **bridge**. Gli IP delle macchine sono stati assegnati in modalità statica per garantire stabilità al laboratorio.

Active Directory

In windows server 2022, si proceda alla creazione **dell'Active Directory Domain Services (AD DS)** tramite server manager. Il server dev'essere poi promosso a Domain Controller creando una nuova foresta con dominio **stars.local**.

Sono stati creati anche i seguenti utenti di dominio:



The screenshot shows the 'Active Directory Users and Computers' console for the 'stars.local' domain. The left pane shows the domain hierarchy with 'Users' selected. The right pane displays a table of users and groups.

Name	Type	Description
Alessandro Criscoli	User	
EpicalHackers	Security Group...	
Mike Star	User	

Configurazione di rete

La modalità Bridge è stata scelta per consentire alle VM di ottenere un indirizzo IP nella stessa subnet della rete fisica host (192.168.1.0/24). Ogni VM è stata configurato con un IP statico per evitare variazioni dovute al DHCP. Il Domain Controller funge anche da server DNS per il dominio **stars.local**

DC

IP - 192.168.1.29 **Subnet Mask** - 255.255.255.0 **Gateway** - 192.168.1.1 **DNS** - 127.0.0.1

Windows 10 Pro

IP - 192.168.1.99 **Subnet Mask** - 255.255.255.0 **Gateway** - 192.168.1.1 **DNS** - 192.168.1.29

SIEM Ubuntu Server

IP - 192.168.1.50 **Subnet Mask** - 255.255.255.0 **Gateway** - 192.168.1.1 **DNS** - 192.168.1.1

La configurazione delle macchine windows è molto lineare, per quanto riguarda ubuntu, la macchina è stata configurata con IP statico tramite netplan, impostando come DNS primario l'ip del DC e come search domain stars.local

```
mike@mslxsr:~$ sudo cat /etc/netplan/50-cloud-init.yaml
[sudo] password for mike:
network:
  version: 2
  renderer: networkd
  ethernet:
    enp0s3:
      dhcp4: no
      addresses:
        - 192.168.1.50/24
      routes:
        - to: default
          via: 192.168.1.1
      nameservers:
        search:
          - stars.local
        addresses:
          - 192.168.1.100
```

Successivamente si è resa necessaria l'installazione dei pacchetti di realmd, sssd, adcli, krb5-user, samba-common-bin. Join al dominio con `sudo realm join -v -U Administrator@STARS.LOCAL stars.local`

Splunk Enterprise

Installazione di Splunk Enterprise 10.2.1

Per il SIEM è stato scelto **Splunk Enterprise 10.2.1**, installato su ubuntu. Splunk è una piattaforma leader nel monitoraggio e analisi dei log di sicurezza. Il pacchetto .deb è facilmente scaricabile dal sito ufficiale. Una volta scompattato e installato tutto con il comando `sudo dpkg -i splunk-10.2.1-c892b66d163d-linux-amd64.deb` Avvio del servizio con il comando `sudo /opt/splunk/bin/splunk start --accept-license --run-as-root`. Una volta dato il comando, il servizio sarà attivo e raggiungibile all'indirizzo; 192.168.1.50:8000

```
mike@mslxsr:~$ sudo /opt/splunk/bin/splunk start --accept-license --run-as-root
[sudo] password for mike:
splunkd 1227 was not running.
Stopping splunk helpers...
Done.
Stopped helpers.
Removing stale pid file... done.
Splunk> Finding your faults, just like mom.
Checking prerequisites...
  Checking http port [8080]: open
  Checking mgmt port [8089]: open
  Checking appserver port [127.0.0.1:8065]: open
  Checking kvstore port [8191]: open
  Checking configuration... Done.
New certs have been generated in '/opt/splunk/etc/auth'.
  Checking critical directories... Done
  Checking indexes...
    Validated: _audit _configtracker _dm_summary _dsappevent _dsclient _dsphonehome _internal _introspection _metrics _metrics_rollup _telemetry _thefishbucket history main summary
  Done
  Checking filesystem compatibility... Done
  Checking conf files for problems... Done
  Checking default conf files for edits... Done
  Validating installed files against hashes from '/opt/splunk/splunk-10.2.1-c892b66d163d-linux-amd64-manifest'
  All installed files intact.
  Done
All preliminary checks passed.
Starting splunk server daemon (splunkd)...
Done
Waiting for web server at http://127.0.0.1:8000 to be available..... Done
If you get stuck, we're here to help.
Look for answers here: http://docs.splunk.com
The Splunk web interface is at http://mslxsr:8000
```

Installazione dello Splunk Universal Forwarder

Per consentire a Splunk di ricevere i log, è stato installato **Splunk Universal Forwarder** sia sul domain controller che sul client windows 10 pro. La configurazione è molto lineare, la connessione è stata configurata verso l'IP del server SIEM 192.168.1.50 sulla porta 9997.

Successivamente al riavvio delle macchine, sarà possibile visualizzare su splunk i loro log.

Verifica ricezione: query: index=main sourcetype="WinEventLog:Security"

The screenshot displays the Splunk Enterprise Search & Reporting interface. The search bar at the top contains the query `index=main sourcetype="WinEventLog:Security"`. Below the search bar, it indicates that 408 events were found for the time range of 28/03/26 17:00:00.000 to 29/03/26 17:47:29.000. The interface shows a list of search results with columns for 'Ora' (Time) and 'Evento' (Event). The first two results are visible, both dated 29/03/26. The first event occurred at 10:47:19.877 AM with EventCode=4634, and the second at 10:47:19.874 AM with EventCode=4624. Both events are from the 'mikeserver' host. The interface also includes a sidebar with 'CAMPI SELEZIONATI' (Selected Fields) and 'CAMPI INTERESSANTI' (Interesting Fields).

i	Ora	Evento
>	29/03/26 10:47:19.877 AM	LogName=Security EventCode=4634 EventType=0 ComputerName=mikeserver.stars.local host = mikeserver source = WinEventLog:Security sourcetype = WinEventLog:Security
>	29/03/26 10:47:19.874 AM	LogName=Security EventCode=4624 EventType=0 ComputerName=mikeserver.stars.local host = mikeserver source = WinEventLog:Security sourcetype = WinEventLog:Security

La ricerca ha restituito gli eventi nelle ultime 24 ore, confermando il corretto funzionamento del forwarding dei log di sicurezza di entrambe le macchine.

Simulazione attacco ed analisi log

Insider Threat

L'insider threat è una minaccia alla sicurezza che proviene da individui all'interno di un'organizzazione, come dipendenti o collaboratori. Questi soggetti possono compromettere i dati o i sistemi aziendali in vari modi, sia intenzionalmente che accidentalmente.

Durante l'analisi simuliamo uno scenario di attacco in due fasi che combina una minaccia interna e un attaccante esterno.

Fase 1 - Insider Threat: un utente interno con accesso alla macchina windows server 2022 ha deliberatamente disabilitato il Windows Defender Firewall e aperto la porta SSH. E' un'azione semplicissima, anche nel caso in cui l'attaccante interno non sia un professionista ma semplicemente un dipendente, con cattive intenzioni, ben indirizzato. Aprendo powershell e inserendo il comando sottostante, il firewall sarà disabilitato rendendo la macchina vulnerabile.

```
PS C:\Windows\system32> Set-NetFirewallProfile -Profile Domain,Public,Private -Enabled False
```

L'abilitazione di SSHserver può essere fatta semplicemente dalle impostazioni di windows

Fase 2 - Attacco Esterno: un attaccante esterno, operante dalla macchina Parrot OS (192.168.1.30), ha sfruttato la finestra di vulnerabilità creata dall'insider per lanciare un attacco di **brute force SMB** contro il Domain Controller tramite tool **Hydra**.

Test del ping:

```
[user@parrot]~$ ping 192.168.1.29
PING 192.168.1.29 (192.168.1.29) 56(84) bytes of data:
64 bytes from 192.168.1.29: icmp_seq=1 ttl=128 time=0.544 ms
64 bytes from 192.168.1.29: icmp_seq=2 ttl=128 time=0.820 ms
64 bytes from 192.168.1.29: icmp_seq=3 ttl=128 time=0.471 ms
```

Proseguiamo con il tentativo di bruteforce:

```
[user@parrot]~$ cat /dev/urandom | tr -dc 'a-z0-9' | fold -w 12 | xargs -n1 shuf | xargs echo | tr '\n' ' '
[user@parrot]~$ hydra -l Administrator -P pass.txt 192.168.1.29 ssh -i 4
Hydra v5.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-03-30 20:05:17
[DATA] max 4 tasks per 1 server, overall 4 tasks, 7 login tries (1:1/pw), ~2 tries per task
[DATA] attacking ssh://192.168.1.29:22/
[22][ssh] host: 192.168.1.29 login: Administrator password: MIK12002!
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-03-30 20:05:18
[user@parrot]~$
```

Dopo aver identificato i servizi attivi sul target mikeserver (192.168.1.29), è stato condotto un attacco di tipo **Brute Force** mirato al protocollo SSH.

Comando utilizzato: `hydra -l Administrator -P pass.txt 192.168.1.29 ssh`

E' stata eseguita una ricerca all'interno del SIEM Splunk per individuare le tracce lasciate dall'attaccante. Per estrarre i dati rilevanti, è stata utilizzata la seguente query:

index=main host="mikeserver" Filtra i log provenienti esclusivamente dal Domain Controller

EventCode=4624, 4625

```
index=main host="mikeserver" (EventCode=4624 OR EventCode=4625)
```

Il risultato ci darà 8.038 eventi. E' possibile rendersi conto che si tratta di un tentativo di brute force per la frequenza degli eventi concentrata in pochissimi secondi.

2026-03-23 15:05:34.711	4624
2026-03-23 15:05:34.802	4624
2026-03-23 15:05:34.815	4625
2026-03-23 15:05:35.023	4624
2026-03-23 15:05:35.507	4624

Dettaglio Event Code:4624

```
30/03/26      03/30/2026 04:42:37.318 PM
23:42:37.318  LogName=Security
               EventCode=4624
               EventType=0
               ComputerName=mikeserver.stars.local
               SourceName=Microsoft Windows security auditing.
               Type=Information
               RecordNumber=14344
               Keywords=Audit Success
               TaskCategory=Logon
               OpCode=Info
               Message=An account was successfully logged on.
```

Event 4625:

```
index=main host="mikeserver" EventCode=4625
```

```
| table _time, Target_UserName, Status, Sub_Status, IPAddress  
| sort - _time
```

2026-03-30 18:04:51.787	0xC000006D	0xC000006A
2026-03-30 18:04:51.594	0xC000006D	0xC000006A
2026-03-30 18:04:51.543	0xC000006D	0xC000006A
2026-03-30 18:04:51.521	0xC000006D	0xC000006A

L'analisi dettagliata dell'evento **4625** ha permesso di confermare la natura dell'attacco. Il valore Status: 0xC000006D unito al Sub_Status: 0xC000006A indica che l'attaccante ha tentato ripetutamente l'accesso con password errate. La velocità di generazione di questi log, rilevata tramite il campo `_time`, esclude tentativi di accessi manuale.

Definizione codici:

This event is generated when a logon session is created. It is generated on the computer that was accessed.

The subject fields indicate the account on the local system which requested the logon. This is most commonly a service such as the Server service, or a local process such as Winlogon.exe or Services.exe.

The logon type field indicates the kind of logon that occurred. The most common types are 2 (interactive) and 3 (network).

The New Logon fields indicate the account for whom the new logon was created, i.e. the account that was logged on.

The network fields indicate where a remote logon request originated. Workstation name is not always available and may be left blank in some cases.

The impersonation level field indicates the extent to which a process in the logon session can impersonate.

The authentication information fields provide detailed information about this specific logon request.

- Logon GUID is a unique identifier that can be used to correlate this event with a KDC event.
- Transited services indicate which intermediate services have participated in this logon request.
- Package name indicates which sub-protocol was used among the NTLM protocols.
- Key length indicates the length of the generated session key. This will be 0 if no session key was requested.

Questo evento viene generato quando viene creata una sessione di accesso (logon). Viene generato sul computer a cui è stato effettuato l'accesso. I campi **Subject** (Soggetto) indicano l'account sul sistema locale che ha richiesto l'accesso. Si tratta comunemente di un servizio come il servizio Server o di un processo locale come Winlogon.exe o Services.exe. Il campo **Logon Type** (Tipo di accesso) indica il tipo di accesso che si è verificato. I tipi più comuni sono 2 (interattivo) e 3 (di rete). I campi **New Logon** (Nuovo accesso) indicano l'account per il quale è stato creato il nuovo accesso, ovvero l'account che ha effettuato il login. I campi **Network** (Rete) indicano la provenienza di una richiesta di accesso remoto. Il nome della workstation non è sempre disponibile e in alcuni casi può essere lasciato vuoto. Il campo **Impersonation Level** (Livello di impersonificazione) indica la misura in cui un processo nella sessione di accesso può impersonificare l'utente. I campi relativi alle **Authentication Information** (Informazioni di autenticazione) forniscono dettagli specifici su questa richiesta di accesso.

Conclusioni

Il laboratorio ha permesso di realizzare e testare un ambiente di sicurezza completo, dalla configurazione dell'infrastruttura Active Directory fino al rilevamento degli attacchi tramite SIEM.

Lo scenario simulato ha dimostrato come una singola misconfiguration possa aprire la strada a un attaccante esterno. Hydra ha condotto un brute force SSH riuscito, lasciando nel Security Log del Domain Controller una sequenza di **Event ID 4625** (tentativi falliti) seguita da un **Event ID 4624** (accesso riuscito), entrambi rilevati e analizzati tramite Splunk Enterprise. La **detection** e la successiva **analisi forense** degli eventi permettono di identificare la natura, la tempistica e la provenienza dell'attacco.

OBIETTIVO	RISULTATO
Ambiente AD virtualizzato	Realizzato AD stars.local
Client aggiunto ad dominio	Windows 10 pro nel dominio
SIEM operativo	Splunk Enterprise
Forwarding log configurato	DC e Client inviano log a Splunk
Evento di sicurezza simulato	Brute force SSH con Hydra da Parrot OS
Rilevamento su SIEM	Event ID 4625 e 4624 rilevati su Splunk